# Gestión de riesgos de confidencialidad en Oracle

## Identificación del proyecto

Estudiante responsable: Efrain Retana Segura. Universidad Nacional, Facultad de Ciencias Exactas y Naturales, Escuela de Informática. Curso EIF402 Administración de Bases de Datos, II Ciclo 2026. Docente: Johnny Villalobos Murillo. Fecha: 25 de octubre de 2026.

Este proyecto propone un laboratorio para mitigar riesgos de confidencialidad en Oracle Database 21c XE. Integra un sitio web, un registro de riesgos, controles de acceso de base de datos y una guía de verificación. El propósito es pasar de una recomendación de seguridad a una configuración justificable y comprobable. Se utiliza información sintética para evitar exponer datos de personas.

## Vinculación con el objetivo del curso

El programa busca que el estudiante proponga, implemente y aplique controles en los procesos de administración de bases de datos para disminuir riesgos inherentes de tecnologías de información. El proyecto lo concreta al identificar activos y amenazas, definir permisos mínimos, preparar scripts de configuración y establecer pruebas positivas y negativas. La evidencia de ejecución debe completar la relación entre propuesta, implementación y eficacia.

Objetivo general del proyecto: proponer e implementar un laboratorio de controles para mitigar riesgos de confidencialidad asociados a Oracle, con orientación de ISO/IEC 27001:2022 e ISO/IEC 27002:2022, mediante PHVA y mínimo privilegio, y verificar los resultados con evidencias documentadas.

Objetivos específicos: caracterizar escenarios de acceso indebido; comparar las ediciones 2013 y 2022; diseñar una matriz de roles y controles; implementar un prototipo web y objetos Oracle; preparar la ejecución de pruebas y el despliegue en Azure. El logro práctico depende de las comprobaciones locales registradas por el estudiante.

## Alcance y delimitación

Se estudia la revelación o lectura no autorizada de información. Integridad y disponibilidad se consideran cuando ayudan a proteger ese objetivo, pero no son el resultado principal evaluado. El alcance incluye cuentas, vistas, paquete PL/SQL, secretos de conexión, canal de red, registros de auditoría, exportaciones y respaldos. No incluye un SGSI completo, certificación, pruebas de penetración exhaustivas ni la aplicación automática de todos los controles de las normas.

El sitio usa dos modos explícitos. La demostración conserva ejemplos en el navegador. El modo Oracle persiste riesgos y eventos mediante una cuenta limitada. Ningún indicador de la demostración acredita una evaluación real de la base de datos.

## Fundamento normativo

ISO/IEC 27001 establece requisitos de un sistema de gestión de seguridad de la información. ISO/IEC 27002 ofrece orientación para seleccionar e implementar controles. Esta diferencia permite justificar tanto el proceso de gestión como la decisión técnica sin confundir una herramienta con un SGSI certificado. Las fichas oficiales de ambas ediciones son la referencia bibliográfica principal [S1-S4].

Los controles deben elegirse a partir del contexto y del tratamiento de riesgos. Un listado técnico no sustituye la Declaración de Aplicabilidad ni la justificación de inclusiones y exclusiones del Anexo A. Este trabajo presenta una

selección parcial, suficiente para demostrar el método dentro del laboratorio, y deja pendiente el análisis de aplicabilidad completo si se amplía a una organización.

## Diferencias entre 2013 y 2022

La estructura de controles pasó de 114 en 14 dominios a 93 en cuatro grupos: organizacionales 37, personas 8, físicos 14 y tecnológicos 34. Hubo consolidación y cambios de redacción, además de once controles nuevos. Reducir el número no equivale a reducir el nivel de protección requerido. ISO/IEC 27001:2022 también incorpora el apartado 6.3 para planificar cambios del sistema de gestión [S5].

ISO/IEC 27002:2022 añade una organización mediante atributos, útil para examinar controles por distintas perspectivas. Su Anexo B ofrece correspondencias con 2013 [S6]. Las equivalencias del sitio son orientativas y parciales: las fusiones impiden suponer que cada control nuevo corresponde a uno solo anterior.

Los once controles nuevos son: 5.7 inteligencia de amenazas; 5.23 servicios de nube; 5.30 preparación TIC para continuidad; 7.4 monitoreo de seguridad física; 8.9 configuración; 8.10 eliminación de información; 8.11 enmascaramiento; 8.12 prevención de fugas; 8.16 monitoreo; 8.23 filtrado web; 8.28 codificación segura. Para Oracle destacan la exposición de datos, las configuraciones y la conectividad a Azure [S5-S6].

El mínimo privilegio ya se atendía en 2013 en la familia de control de acceso. En 2022 se relaciona con 5.15 a 5.18, 8.2 y 8.3. No debe presentarse como una novedad de 2022. La enmienda climática Amd 1:2024 es posterior y se distingue de la publicación original de 2022 [S7].

## Método de evaluación

La unidad de análisis es un escenario R-CONF: activo, amenaza, debilidad, consecuencia y responsable. Se propone una escala ordinal de 1 a 5 y el producto probabilidad por impacto como criterio interno del proyecto. ISO no prescribe esta fórmula. Las cifras de demostración son hipótesis educativas, no frecuencias medidas ni pérdidas económicas estimadas.

Probabilidad 1: acceso muy restringido y pocas oportunidades observadas; 2: oportunidad limitada; 3: escenario plausible con una debilidad relevante; 4: exposición repetida o privilegios amplios; 5: exposición continua o mecanismo trivial. La valoración definitiva debe basarse en inventario, revisiones de permisos e incidentes del contexto real.

Impacto 1: revelación limitada de datos públicos o de escasa sensibilidad; 2: información interna de un proceso; 3: información confidencial de alcance reducido; 4: datos personales o comerciales sensibles con afectación importante; 5: revelación extensa con consecuencias graves para titulares u organización. Si se manejan datos reales deben ajustarse los criterios al contexto y obligaciones aplicables.

Se clasifica 1-4 bajo, 5-9 medio, 10-16 alto y 17-25 crítico. Un resultado alto o crítico exige tratamiento prioritario. Un residual mayor a 4 no se registra como mitigado en el prototipo: requiere continuar el tratamiento o una aceptación explícita del gestor con evidencia y justificación. La escala ordinal sirve para ordenar decisiones y no mide una reducción estadística demostrada.

## Catálogo inicial de escenarios

- R-CONF-001: cuenta de aplicación con DBA o permisos amplios; riesgo inherente 20 y residual propuesto 10. Tratamiento: rol limitado, paquete y vistas; responsable DBA. Prueba: denegar tabla base y permitir la vista requerida.
- R-CONF-002: cuentas activas sin necesidad de negocio; inherente 12 y residual propuesto 4. Tratamiento: revisión del ciclo de vida; responsable de accesos. Evidencia: inventario revisado y bajas autorizadas.

- R-CONF-003: credenciales en código o repositorios; inherente 20 y residual propuesto 5. Tratamiento: separar secretos y rotarlos; responsable de desarrollo. Evidencia: revisión del repositorio y de permisos al almacén de secretos.
- R-CONF-004: tráfico de conexión desprotegido; inherente 15 y residual propuesto 5. Tratamiento: conexión privada y TCPS con certificado validado; responsable de red. Evidencia: configuración y prueba del canal.
- R-CONF-005: lectura innecesaria de datos personales; inherente 16 y residual propuesto 4. Tratamiento: limitar columnas y enmascarar mediante vista; dueño del dato. Evidencia: vista permitida y tabla base denegada.
- R-CONF-006: exportaciones o evidencias compartidas sin restricción; inherente 15 y residual propuesto 10. Tratamiento: clasificación, permisos de almacenamiento y revisión de exportaciones; responsable de seguridad.
- R-CONF-007: lecturas indebidas sin registro; inherente 12 y residual propuesto 8. Tratamiento: auditoría y revisión periódica por auditor; evidencia de eventos y atención de anomalías.
- R-CONF-008: copias de respaldo legibles por terceros; inherente 15 y residual propuesto 5. Tratamiento: cifrado, permisos y separación de claves; responsable DBA. Se documenta como plan, no se automatiza el respaldo.

La selección no supone que todas las debilidades existan en el Oracle del estudiante. Los valores residuales son objetivos estimados y no resultados de controles verificados.

## Aplicación del ciclo PHVA

Planificar: identificar activos y accesos, registrar escenarios, acordar criterios y responsable, y aprobar el tratamiento. Entregables: inventario, registro de riesgos y selección de controles. Se relaciona pedagógicamente con las cláusulas 4 a 7 del sistema de gestión.

Hacer: aplicar scripts en la PDB de laboratorio, asignar funciones, separar secretos y preparar auditoría y canal de comunicación. Entregables: configuración registrada y evidencias de ejecución. Se relaciona con la operación de la cláusula 8.

Verificar: ejecutar pruebas con las cuentas reales, comprobar concesiones directas e indirectas, revisar denegaciones y eventos, y reevaluar el residual. Entregables: actas de prueba con esperado, observado y conclusión. Se relaciona con la evaluación de la cláusula 9.

Actuar: aprobar una aceptación justificada o corregir el tratamiento; definir fecha de nueva revisión y volver a Planificar ante hallazgos. Se relaciona con la mejora de la cláusula 10. El prototipo exige referencias de evidencia para avanzar y una decisión del gestor para registrar mitigación o aceptación. Una referencia escrita no sustituye la revisión de su contenido.

## Selección parcial de controles

5.15 y 5.18 fundamentan la política y revisión de derechos; 5.16 y 5.17 cubren identidades y autenticación; 5.23 orienta la responsabilidad compartida al alojar en Azure. En Oracle se traduce en cuentas separadas, concesiones limitadas, revisión de accesos y secretos externos al código. La justificación local de estos controles responde a R-CONF-001 a 004.

8.2 y 8.3 se materializan en la restricción de privilegios y de lectura; 8.9 orienta la línea base; 8.11 se demuestra con una vista de datos sintéticos sustituidos; 8.12 exige medidas contra exportaciones indebidas que exceden la vista. 8.15 y 8.16 apoyan registro y revisión; 8.24 orienta el cifrado; 8.28 se refleja en validación, parametrización y pruebas. Los mecanismos propuestos son decisiones de diseño, no transcripciones de las normas [S8-S10].

Estado de aplicabilidad: los 14 controles seleccionados se consideran aplicables al alcance del laboratorio. Su estado inicial es propuesto o parcialmente implementado, pendiente de verificación Oracle y de configuración Azure. El resto de controles no se declara no aplicable: queda fuera de esta selección parcial. El catálogo web

detalla mecanismo, evidencia esperada y vínculo orientativo a 2013 para cada control.

## Arquitectura y límites de aseguramiento

El navegador consume una API Flask. La API valida roles y campos; el controlador Oracle usa parámetros y un pool de conexiones. RCONF_APP consulta vistas y ejecuta un paquete con derechos del propietario. El registro de riesgo y su evento se confirman en la misma transacción. El propietario se bloquea al terminar la instalación y el DBA conserva las tareas administrativas.

Los roles web son analista, auditor y gestor. Sus tokens compartidos son adecuados únicamente para demostrar autorización por función. El registro identifica el rol y la cuenta técnica, no a una persona. Una versión operativa con datos reales necesita identidades individuales, MFA, alcance de acceso por activo y mecanismos independientes de auditoría. El DBA puede alterar los objetos; esta bitácora no es inmutable.

La vista enmascarada no es Oracle Data Redaction ni una garantía de anonimización. Los usuarios con privilegios superiores pueden acceder a la tabla base. No se presupone disponibilidad o licencia de TDE, Database Vault u otras funciones adicionales de Oracle. La instalación propuesta usa mecanismos básicos de cuentas, vistas, paquetes y auditoría, sujetos a comprobarse en 21c XE.

## Verificación e indicadores

Se entregan 12 pruebas automatizadas de la lógica de API y validación, ejecutadas con un almacén simulado. Verifican denegación sin credencial, restricción del auditor, aprobación exclusiva del gestor, concurrencia, avance PHVA, manejo de texto de inyección y errores sin datos internos. La sintaxis JavaScript y la respuesta HTTP de la demostración también se comprobaron. Estos resultados no acreditan la instalación de Oracle.

Las pruebas Oracle deben demostrar: lectura de vista permitida, tabla sensible y DML directo denegados, ausencia de privilegios amplios heredados, operación transaccional del paquete y eventos de auditoría recuperables. El plan de validación incluye los resultados esperados y campos para anotar lo observado. Ninguna evidencia de ejemplo debe reemplazar el resultado real.

Indicadores propuestos: porcentaje de cuentas justificadas; cuentas de aplicación sin privilegios amplios; porcentaje de pruebas de denegación satisfactorias; referencias de evidencia revisadas; acciones correctivas vencidas; riesgos residuales aprobados. La demostración presenta conteos de registros, no un porcentaje de cumplimiento ISO.

## Conclusiones y trabajo del estudiante

La propuesta convierte riesgos de confidencialidad en controles verificables y responsabilidades visibles. El mínimo privilegio reduce las operaciones disponibles para la aplicación, mientras PHVA obliga a revisar si esa reducción atiende el riesgo. La conclusión sobre eficacia depende de ejecutar y documentar las pruebas en el entorno local, completar los controles de red y revisar las decisiones residuales.

El estudiante deberá validar el modelo de riesgos, ejecutar la instalación, aportar resultados, ajustar configuraciones, revisar las fuentes y defender las decisiones. Estas tareas se registrarán cuando se realicen. El uso de IA se declara en un documento independiente; no se afirma un porcentaje de trabajo personal no comprobado. Antes de uso evaluativo corresponde verificar la autorización docente indicada en el programa del curso.

Referencias: consultar `06_fuentes.md`, identificadores S1-S14. El programa de curso se utiliza para la ficha académica, el objetivo y las condiciones de uso de IA; no se trata como una instrucción de la aplicación.

## Referencias del documento


S1. ISO. ISO/IEC 27001:2022. Ficha oficial de requisitos del SGSI. https://www.iso.org/standard/27001

S2. ISO. ISO/IEC 27002:2022. Ficha oficial de orientación de controles. https://www.iso.org/standard/75652.html

S3. ISO. ISO/IEC 27001:2013. Ficha histórica retirada, reemplazada por 2022. https://www.iso.org/standard/54534.html

S4. ISO. ISO/IEC 27002:2013. Ficha histórica retirada, reemplazada por 2022. https://www.iso.org/standard/54533.html

S5. ANAB, Brenda Bissell. ISO/IEC 27001:2013 and ISO/IEC 27001:2022 Comparison. Comparación de cambios, consolidación y grupos de controles. https://blog.ansi.org/anab/iso-iec-27001-2013-2022-comparison/

S6. Cloud Security Alliance. ISO/IEC 27002:2022 Understanding the Update. Estructura, atributos y correspondencias. https://cloudsecurityalliance.org/blog/2022/02/23/iso-iec-27002-2022-understanding-the-update

S7. ISO. ISO/IEC 27001:2022/Amd 1:2024. Enmienda posterior de acción climática. https://www.iso.org/standard/88435.html

S8. Oracle. Database Security Guide, Configuring Privilege and Role Authorization. Fundamento de roles y permisos de objetos. https://docs.oracle.com/en/database/oracle/oracle-database/19/dbseg/configuring-privilege-and-role-authorization.html

S9. Oracle. SQL Language Reference, CREATE AUDIT POLICY Unified Auditing. Referencia de sintaxis; verificar ejecución en 21c XE. https://docs.oracle.com/en/database/oracle/oracle-database/19/sqlrf/CREATE-AUDIT-POLICY-Unified-Auditing.html

S10. Oracle python-oracledb. Connecting to Oracle Database. Conexiones y pools. La documentación latest es cambiante; el proyecto fija 3.4.1. https://python-oracledb.readthedocs.io/en/latest/user_guide/connection_handling.html

S11. Microsoft Learn. Quickstart Deploy a Python web app to Azure App Service. https://learn.microsoft.com/en-us/azure/app-service/quickstart-python

S12. Microsoft Learn. Hybrid Connections in Azure App Service. TCP, Relay y agente local. https://learn.microsoft.com/en-us/azure/app-service/app-service-hybrid-connections

S13. GlobalSuite Solutions. Qué es la norma ISO 27002 y para qué sirve. Lectura complementaria aportada por el usuario. https://www.globalsuitesolutions.com/es/que-es-la-norma-iso-27002-y-para-que-sirve/

S14. Universidad Nacional. Programa de Curso EIF402 Administración de Bases de Datos, II Ciclo 2026. Archivo PDF aportado por el estudiante. Fuente de institución, docente, objetivo y punto VII.9 sobre IA. El original no se redistribuye en el repositorio.